WINSTONE CRM

# Production Readiness / Audit Report

Document 1.0.0 · Audit 2026-09-30 13:40 UTC (19:40 Asia/Dhaka) · Version c9a5020 + final audit changes

## Implementation audit: PASS (code, database and automated tests)

This covers code, database and automated-test verification only. External operational checks are listed separately below and are not certified here. No legal or security guarantee is made.

| Item | Result | Evidence |
|---|---|---|
| 1. Call readiness | PASS (code/test) | Web startMyCall and Android /api/public/agent/call-start derive the agent from the signed-in session or device token only. Order: 9:05 briefing → staff photo → one-pending-report lock (unique DB index) → lead must be assigned to this agent. Fixed during the audit: unassigned pool leads could be dialled; now refused. |
| 2. Agent scope | PASS (code/test) | Agent snapshot queries filter by the caller's profile id on the server; HQ/IT PIN scope reads the whole floor; RLS on every public table (0 tables without RLS). |
| 3. Data integrity | PASS (code/test) | Dashboard snapshot pages through all rows (no latest-500 cap). 3,980 leads, 2,935 reports read from real records. One staff-created row named "IT Test" (source agent_app) exists and is kept — leads are never deleted. |
| 4. Contact-close reason | PASS (code/test) | DB trigger enforce_contact_close_reason rejects a closed report without a canonical reason; "other" requires a note (no_follow_up_note). log_contact_close writes an immutable contact_closed lead event. Shared list in contact-close-reasons.ts (web) and ContactCloseReasons.kt (Android). |
| 5. Permanent history | PASS (code/test) | Append-only: lead_events, lead_state_changes, follow_up_changes block UPDATE/DELETE by trigger; no UPDATE/DELETE policies. Triggers log assignment/status/work state/temperature, report status + corrections, new calls, follow-up create/reschedule/complete/cancel. Each history row carries a unique correlation_id. |
| 6. Lead 360 | PASS (code/test) | Full timeline read in 1000-row pages from all event sources, de-duplicated by id; filters phone/ID/name/agent/source/requirement/reason/event/status/date; cursor pages of 40 with total count. |
| 7. Reports / export | PASS (code/test) | Server-built CSV and print-ready HTML for filtered Lead 360 results (filters + generated-at stamp, formula-neutralised cells); per-lead full-history CSV/print; follow-up history Excel/PDF scoped HQ=all, agent=own. |
| 8. Canonical manual | PASS | system-manual.ts v1.1.0 → /manual page and /winstone-system-manual.pdf, card in Executive HQ and IT Console. |
| 9. Home daily performance | PASS (code/test) | Top 3 computed from that day's real reports/follow-ups; score breakdown shown; ties broken by calls → reports → talk minutes → id. |
| 10. Responsive QA | PASS (public pages) | /, /manual, /desk, /audit-report, /handover at 390/768/1280/1920 px: no horizontal overflow, no page errors. PIN/sign-in-only screens were not rendered in the automated check. |
| 11. Tests | PASS | tsgo --noEmit: 0 errors. bunx vitest run: 33 files, 205 tests passed. |

## Scope audited

Source code (web + server + Android sources), database schema, triggers, indexes and RLS, call initiation and reporting paths, history model, 09:05 briefing gate, Lead 360, exports, manual and public-page responsive layout.

## Architecture summary

Web app and server functions run on one TanStack Start deployment; Lovable Cloud database with row-level security; Android app (Kotlin) calls from the agent's own SIM and syncs through device-token APIs under /api/public/agent.

Lead sources → LeadHub Nexus (normalise, dedupe) → canonical lead database (unassigned) → LeadHub quantity assignment → agent → call → report → CRM derives score/priority → follow-up or contact close.

## Role / permission matrix

| Role | Leads | Assign | Approve accountability | System settings |
|---|---|---|---|---|
| Agent (all peers) | Own assigned only | No | No | No |
| Executive HQ (PIN) | All (read) | No | Yes | No |
| IT Console (PIN) | All (read) | No | No (monitor only) | Yes |
| LeadHub Nexus (own PIN) | Pool | Yes — only path | No | No |

## Call lifecycle

Agent taps call → server checks briefing, photo, pending report and lead ownership → call_started event → call from own SIM → recording/call row synced (duplicate-safe by client_upload_id / external_call_id) → mandatory post-call report (one pending per agent) → submit validated by DB triggers.

## Lead lifecycle

Imported → unassigned → assigned by LeadHub → called → reported → follow-up or contact closed with reason → completed/converted. Never hard-deleted; duplicates parked as duplicate_skipped. Phone numbers normalised to Bangladesh format with a unique phone key.

## Follow-up lifecycle

Created from a report with a structured reason → reminders 30 min before and every 3 h while overdue → rescheduled / completed / cancelled. Delete is blocked; every change writes old/new time, status, reason, note and actor.

## Permanent history / audit model

lead_events (facts), lead_state_changes (field old/new), follow_up_changes (follow-up old/new), audit_logs (privileged actions). History tables reject update/delete; timestamps stored in UTC and shown in Asia/Dhaka.

## 09:05 briefing gate

After 09:05 Asia/Dhaka each agent must acknowledge the current policy version (2026-09-30-v1) for the current business date. Enforced server-side on call start (web + Android), report submit, follow-up complete/reschedule, WhatsApp logging, lead sorting and new-number calls. Acknowledgements are unique per agent/date/version and immutable.

## Lead 360 and filtering

HQ search by phone, lead ID, name, agent, source, requirement, reason, event type, follow-up status and date range, with totals and cursor pages. Click a lead/phone to open its complete timeline.

## Reporting / export

Filtered Lead 360 CSV + Print/PDF (server-built, with active filters and generated-at), full per-lead history CSV/print, follow-up history Excel/PDF, project reports, shift summaries at 12:50 and 17:30.

## Daily performance

Score = connections×4 + reports×2 + follow-ups×1.5 + talk minutes×0.4, rounded. Revealed on Home at 17:30 Dhaka; breakdown shown per card.

## Security / server authorization

All mutations resolve the caller on the server (session bearer, device token or signed PIN token); client-supplied actor ids are not accepted. PINs are server-verified secrets. RLS enabled on every public table. Two intentionally accepted scan findings remain documented.

## Duplicate / idempotency controls

Unique: one pending report per agent, call client_upload_id, external_call_id, lead phone keys, briefing ack per agent/date/version, history correlation_id. Offline replays use the same upload ids.

## Test results

tsgo --noEmit → 0 errors

bunx vitest run → Test Files 36 passed (36); Tests 239 passed (239)

Database checks: 0 public tables without RLS; 0 UPDATE/DELETE policies on history tables; history triggers present.

UI smoke (Playwright, public pages, 4 widths) → no overflow, 0 page errors.

## Not verified by this audit (external / operational)

Live lock was not executed because it would interrupt real users; equivalent behavior is verified through automated controlled-date tests (maintenance 14th 00:00 Dhaka lock, verified payment, unlock expiry/re-lock, 09:05 briefing before/after/ack/next-day/stale-version). Real-device calls and recordings on agents' phones; carrier behaviour; Android release build (no Android SDK in the audit environment); signed-in agent/HQ/IT sessions end-to-end; WhatsApp Business API (not connected — tap-to-chat only); production deployment configuration; client acceptance. Staff must upload photos before calling. Historical follow-up reschedules before the change log existed cannot be reconstructed.

## Deployment / release

Published at https://crm1.winstonebd.com (also webcrm-v1.lovable.app). Publishing is done from the editor's Publish button. Android APK is distributed from the IT Console releases panel.

## Client handover checklist

☐ Publish the latest version

☐ Every agent uploads a staff photo

☐ Install/update Android app on each agent phone and test one real call + report

☐ HQ, IT and LeadHub PINs handed to named owners

☐ Import leads via LeadHub and assign a test quantity

☐ Confirm 09:05 briefing and 17:30 Top 3 on a working day

☐ Client sign-off